Sécurité des systèmes informatiques

Les malwares

Abdeltouab Belbekkouche

a.belbekkouche@umontreal.ca

Université de Montréal

Contenu

- Virus
- Ver
- Cheval de Troie
- Botnet
- Porte dérobée
- Bombe logique
- Rootkit
- Spyware
- Adware
- Keylogger
- Ransomware

Malware

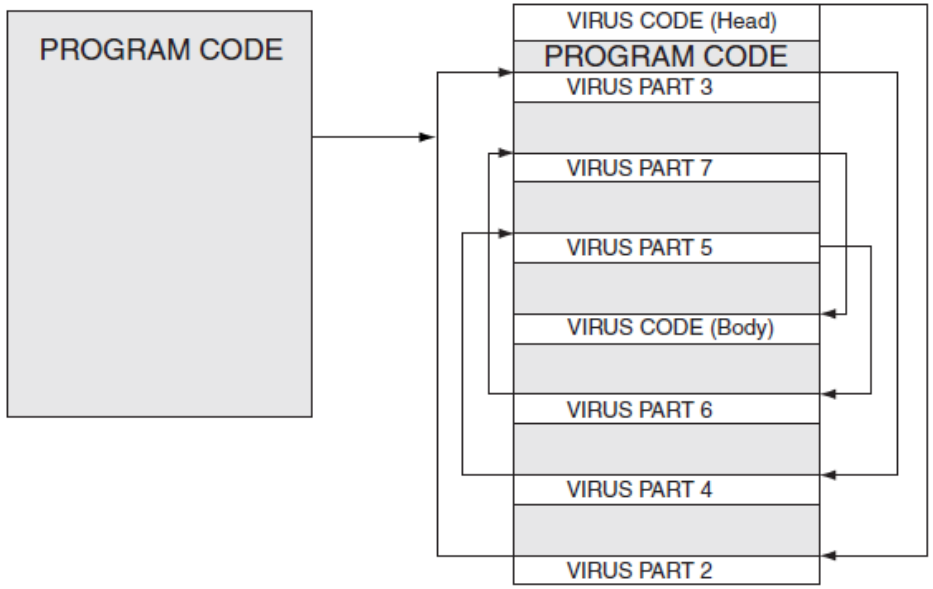
- **Programme malveillant** ou **maliciel**
- Un programme ou une partie de programme destiné à perturber, altérer ou détruire tout ou partie des éléments logiciels indispensables au bon fonctionnement d'un système informatique
- Entre dans un système informatique (ordinateur)
  - Sans l'autorisation ni la connaissance de son propriétaire
- Fait référence à une large variété de logiciels malicieux néfastes ou gênants

Virus

- Tout programme d'ordinateur capable d'infecter un autre programme d'ordinateur en le modifiant de façon à ce qu'il puisse à son tour se reproduire
- Un « petit » programme informatique situé dans le corps d'un autre, qui lorsqu'on le lance se charge en mémoire et exécute les instructions que son auteur a programmées
- Code malicieux qui se reproduit **sur le même ordinateur**
- Ne peut pas se propager automatiquement à un autre ordinateur
  - Repose sur l'action de l'utilisateur pour se propager à d'autres ordinateurs
- Les virus sont attachés aux fichiers
- Les virus se propagent en transférant les fichiers infectés

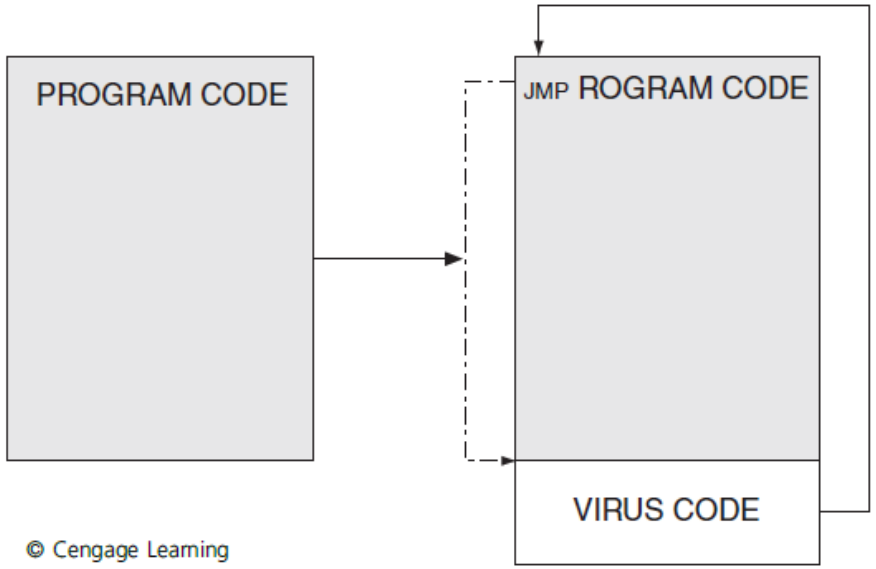
Virus (suite)

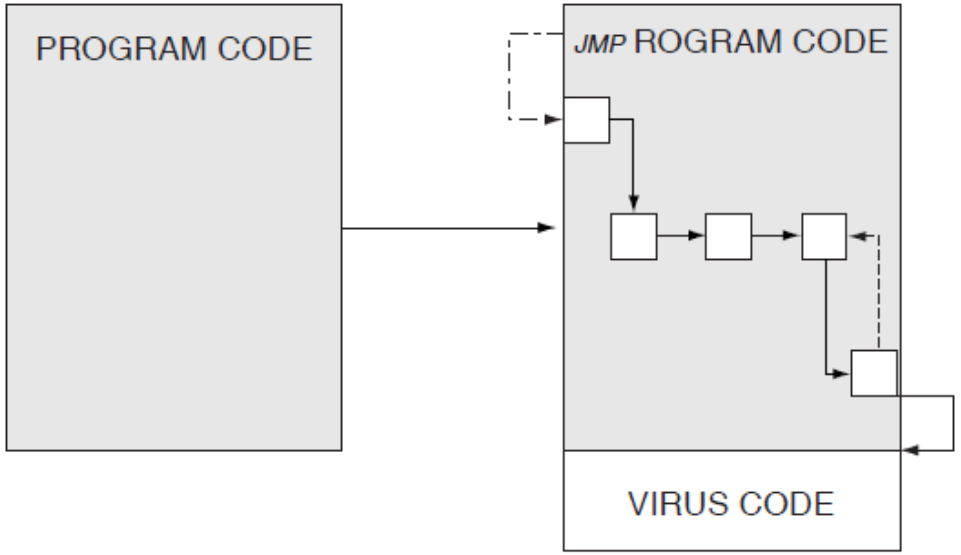
- Types d'arrangements dans un fichier infecté



Split (scission)

Appender (ajout)

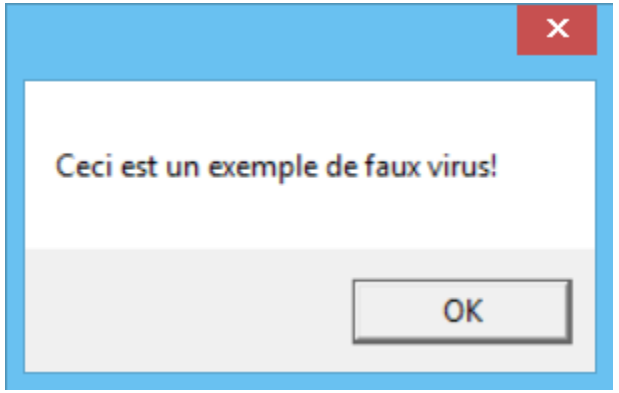




Swiss cheese (fromage suisse)

Virus (suite)

- Quand un programme infecté est lancé
  - Le virus se propage à un autre fichier sur le même ordinateur
  - Le virus actionne sa charge utile (*payload*)
- Le virus peut afficher un message ennuyeux à l'écran
  - Ou peut être beaucoup plus néfaste
- Exemples
  - Éteindre l'ordinateur régulièrement
  - Effacer des fichiers ou reformater le disque dur
  - Changer les paramètres de sécurité de l'ordinateur



Virus (suite)

- Quelques types de virus
  - Virus mutant
    - Virus réécrits par d'autres utilisateurs afin de modifier leur comportement ou leur signature (c.-à-d. **la succession de bits qui les identifie**)
  - Virus polymorphe
    - Virus qui peuvent prendre plusieurs formes en changeant leur signature et qui ont la capacité de chiffrer et de déchiffrer leur signature
  - Rétrovirus (Virus flibustier ou *bounty hunter*)
    - Virus ayant la capacité de modifier les signatures des antivirus afin de les rendre inopérants
  - Virus de secteur d'amorçage (virus de *boot*)
    - Virus capable d'infecter le secteur de démarrage d'un disque dur (MBR, *Master Boot Record*)
  - Virus trans-applicatif (virus de macros)
    - Généralement, les applications Microsoft qui utilisent VBScript du langage de Visual Basic, incluant la messagerie électronique

Ver

- *Worm*
- Exploite les vulnérabilités des applications et des systèmes d'exploitation
- Envoie des copies de lui-même à d'autres machines sur le réseau
- Un ver peut
  - Consommer des ressources
  - Laisser une charge utile pour endommager les systèmes infectés
- Exemple d'actions
  - Supprimer des fichiers
  - Permettre le contrôle à distance de la machine infectée par l'attaquant

Ver (suite)

- Principe de fonctionnement: exemple du Ver créé par Robert T. Morris de l'université Cornell en 1988
  - S'introduire dans une machine de type Unix
  - Dresser une liste des machines qui lui sont connectées
  - Se faire passer pour un utilisateur auprès des autres machines
  - Forcer (utiliser) les mots de passe à partir d'une liste de mots
  - Créer un petit programme sur la machine infectée pour pouvoir se reproduire
  - Se dissimuler sur la machine infectée, et ainsi de suite …
- Parades (contre-mesures)
  - Mise à jour régulière des systèmes d'exploitation et des applications
  - Utilisation d'un pare-feu qui empêche l'accès à des services réseau de façon non autorisée

Virus versus Ver

Action	Virus	Ver
Propagation à d'autres ordinateurs	Par l'utilisateur	En utilisant le réseau
Méthode d'infection	Insère son code dans un fichier	Exploite les vulnérabilités d'une application ou d'un système d'exploitation
Requiert une action de l'utilisateur?	Oui	Non
Peut être contrôlé à distance?	Non	Oui

Cheval de Troie

- *Trojan horse*
- Un code (programme) nuisible placé dans un programme sain
- Logiciel qui fait autre chose que ce qui est annoncé
- Un programme informatique ouvrant une porte dérobée (*backdoor*) dans un système pour y faire entrer un pirate ou d'autres programmes indésirables
- Typiquement, un programme exécutable
- Parfois apparaît comme un fichier de données
- Exemple
  - L'utilisateur télécharge un logiciel gratuit
  - Ce programme scanne le système pour chercher des mots de passe et des numéros de carte de crédit
  - Puis envoie les informations trouvées à l'attaquant distant via le réseau

Cheval de Troie (suite)

- Symptômes d'une infection
  - Activité anormale de la carte réseau de l'ordinateur: des données sont transférées en l'absence d'activité de la part de l'utilisateur
  - Des réactions anormales de la souris
  - Des ouvertures impromptues de programmes
  - Des plantages à répétition
- Principe de fonctionnement
  - Le pirate insère son code troyen dans un programme (un petit jeu, une copie piratée d'un logiciel, etc.)
  - Une fois ce fichier lancé, le cheval de Troie ouvre un port réseau sur la machine pour permettre à un pirate d'en prendre le contrôle
  - Le programme peut informer le pirate du bon déroulement de l'opération ou le pirate peut utiliser un scanneur de port pour recenser les machines infectées sur le réseau mondial
  - Le pirate peut injecter n'importe quel autre programme et créer un **Botnet**

Botnet

- Il s'agit de rassemblement de machines piratées et contrôlées à distance par des pirates
- Un ordinateur infecté par un programme qui permet son contrôle à distance est appelé **Zombie**
  - Souvent cheval de Troie, ver ou virus
- Un groupe d'ordinateurs zombies est appelé **Botnet**
- Un Botnet peut comporter des milliers de machines qui sont loués à des personnes désirant avoir des activités frauduleuses (pollupostage (*spamming*), déni de service distribué (DDOS), propagation de malwares, manipulation des sondages en ligne, etc.)
- Le protocole **HTTP** est souvent utilisé pour contrôler les zombies à distance
- Peut rester actif pendant plusieurs années
- Un large pourcentage de zombies sont accessibles à tout moment
  - Grâce à la **démocratisation de l'accès à Internet**

Porte dérobée

- *Backdoor*
- Code malicieux qui change les paramètres de sécurité du système informatique pour donner accès au système infecté
- Pratique courante par les développeurs d'applications
  - L'intention est d'enlever le *backdoor* dans la version de production de l'application

Bombe logique

- Code malveillant qui reste dormant
  - Déclenché à une date donnée ou suite à un évènement logique spécifique
  - Puis exécute son activité malicieuse
- Difficile à détecter avant son déclenchement
- Exemple

Description	Raison de l'attaque	Résultats
Une bombe logique a été implantée dans un réseau d'ordinateurs d'une compagnie de services financiers. Conséquence: des données sensibles ont été supprimées de 1000 ordinateurs de la compagnie.	Un employé mécontent qui croyait que cet évènement allait faire chuter la valeur en bourse de l'action de cette compagnie et qu'il pourra en profiter.	La bombe s'est déclenchée mais l'employé a été attrapé et condamné à 8 ans de prison et 3,1 millions de $ de compensation à son ex employeur.

Rootkit

- Outil logiciel utilisé pour cacher l'existence d'autres logiciels malveillants
- Nettoyer les entrées correspondantes dans les fichiers de journalisation (*log*)
- Remplacer certains fichiers du système d'exploitation
  - Avec des versions conçues pour ignorer les activités malveillantes
- Détecter un rootkit peut être effectuée par
  - La plupart des antivirus actuels
  - Des utilitaires qui comparent le contenu des fichiers avec la version originale (Tripwire, AIDE, Windows Defender Offline, etc.)
- Supprimer un rootkit peut s'avérer difficile
  - Écraser le rootkit, reformater le disque dur, réinstaller les systèmes d'exploitation, etc.

Spyware

- Espiogiciel
- Un programme chargé de recueillir des informations sur l'utilisateur de l'ordinateur dans lequel il est installé (on l'appelle parfois **mouchard**)
- Ces informations sont envoyées à l'entité qui le diffuse pour lui permettre de dresser le profil des internautes (on parle de **profilage**)
- Les informations récoltées peuvent être:
  - Les adresses Web (URL) des sites visités
  - Les mots-clés saisis dans les moteurs de recherche
  - L'analyse des achats réalisés via Internet, voire les informations de paiement bancaire
  - Des informations personnelles (numéro d'assurance sociale, date de naissance, etc.)
- Les spywares s'installent généralement en même temps que d'autres logiciels (gratuiciels (*freeware*) ou partagiciels (*shareware*) en général)
  - La gratuité est obtenue contre la cession de données à caractère personnel

Spyware (suite)

- Souvent utilisé pour
  - La publicité
  - Collecter des informations personnelles
  - Changer la configuration de l'ordinateur
- Effets négatifs
  - Consommation de mémoire vive
  - Utilisation d'espace disque
  - Mobilisation des ressources du processeur
  - Plantage d'autres applications
  - Gêne ergonomique: ouverture d'écrans publicitaires ciblés en fonction des données collectées par exemple

Adware

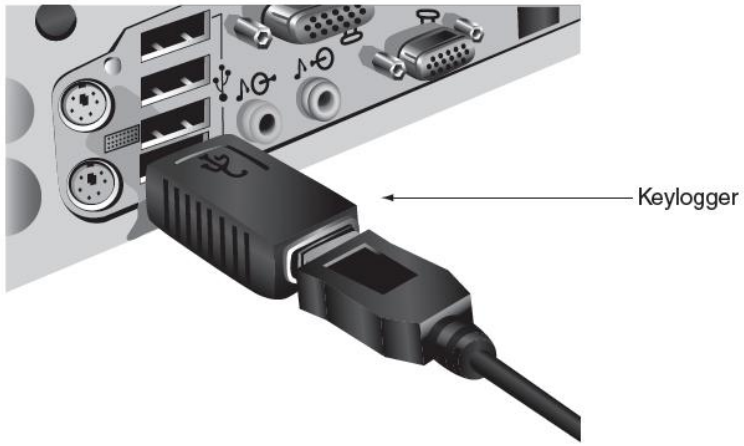
- Programme qui livre un contenu publicitaire
  - D'une manière non prévue et non voulue de l'utilisateur
- Afficher des bannières publicitaires et des *popups*
- Ouvrir, aléatoirement, de nouvelles fenêtres du navigateur
- Peut effectuer le suivi (*tracking*) des activités de l'utilisateur en ligne
- Inconvénients
  - Affichage de contenus indésirables
  - Dégradation des performances de l'ordinateur et perte de productivité
  - Nuisance

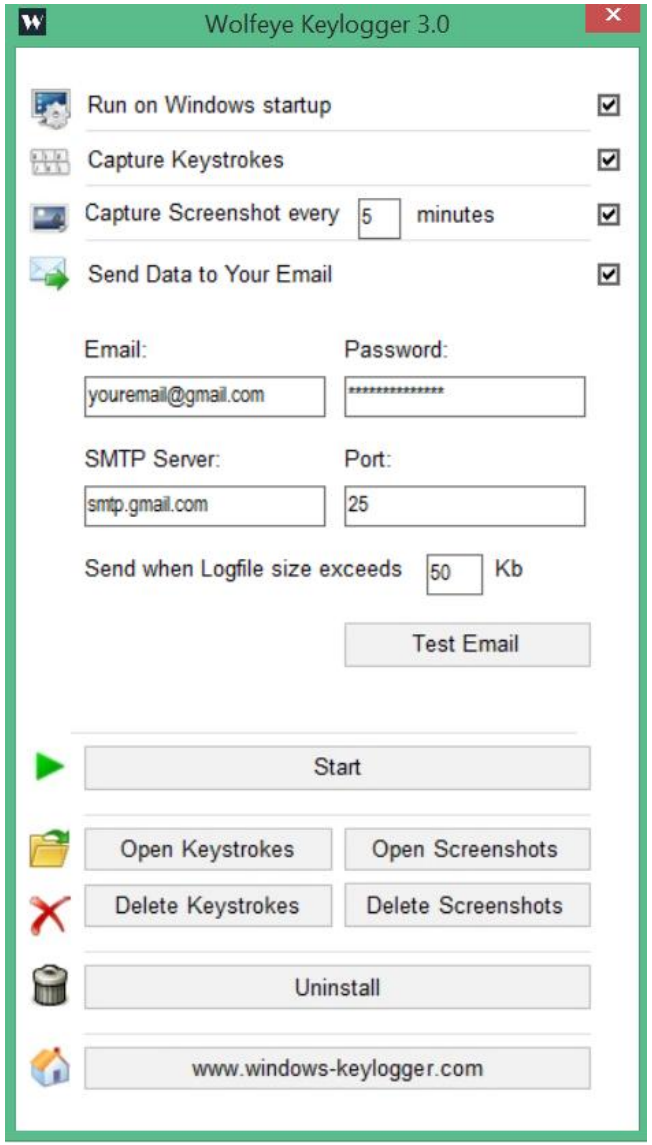
Keylogger

- Littéralement « enregistreur de touches »
- Dispositif chargé d'enregistrer les frappes de touches du clavier et de les enregistrer, à l'insu de l'utilisateur ➔ dispositif d'espionnage!
- Peut servir pour récupérer les **mots de passe** et d'autres informations personnelles des utilisateurs de l'ordinateur infecté
- Certains Keylogger sont capables d'enregistrer
  - Les mots de passe
  - Les URL visitées
  - Les courriels consultés ou envoyés
  - Les fichiers ouverts
  - Voire, créer une vidéo retraçant toute l'activité de l'ordinateur
- L'information enregistrée est récupérée plus tard par l'attaquant

Keylogger (suite)

- Peut être logiciel ou matériel





- **Parades**
  - Vigilance: ne pas installer de logiciels dont la provenance est douteuse
  - Prudence: lors de la connexion à partir d'un ordinateur tiers

Ransomware

- Rançongiciel
- Logiciel malveillant don't le but est de soutirer de l'argent à leurs victimes
- Il existe deux types de ransomwares
  - **Logiciels qui se contentent de faire peur aux utilisateurs:** l'ordinateur de la victime devient très difficile à utiliser, car le logiciel bloque la plupart des applications
  - **Les ransomwares « chiffreur »:** beaucoup plus agressifs, car ils chiffrent tout ou partie des espaces de stockage de données de la victime
    - Les données sont chiffrées en tâche de fond
    - Le malware affiche en suite un message demandant le versement d'une rançon contre un moyen de déchiffrer les données
- **Parades**
  - Toujours utiliser un antivirus à jour
  - Procéder à des sauvegardes périodiques: en utilisant des solutions d'infonuagique (*Cloud*) par exemple